

GOVERNANCE, RISK AND COMPLIANCE ASSESSMENT REPORT

NexaLearn Digital Services Limited

Name: Madubonu Chisom

Student Reg No: C11 26 CGRCE 17235

Date: 25 July 2026

1. EXECUTIVE SUMMARY

NexaLearn Digital Services Limited experienced a data breach on 12 August 2025 resulting in the disclosure of 1,240 learner records. The root causes were a misconfigured public storage container, use of shared emergency-admin credentials without MFA, and delayed offboarding of a contractor account. This GRC assessment identified 8 material risks across Access Management, Third-Party Risk, AI Governance, and Regulatory Compliance. The organization's current control maturity is rated as 'Developing'. Without immediate remediation, NexaLearn faces potential regulatory fines under NDPA 2023 and GDPR, and reputational damage. This report recommends a 90-day remediation plan requiring Board approval of \$33,000.

2. ORGANIZATIONAL CONTEXT

NexaLearn is a Nigerian EdTech company providing online learning to 18,000 learners, including EU residents. The organization employs 60 full-time staff and 25 contractors.

Critical Assets: Learner Personally Identifiable Information (PII), Payment Card Data, Learning Management System (LMS), and AI-based Admissions Tool.

Regulatory Landscape: NexaLearn is subject to Nigeria Data Protection Act 2023 due to location, and GDPR due to processing of EU learner data. Contractual obligations include PCI DSS v4.0 for payment processing.

Assumptions: Breach has occurred. No Data Processing Agreement exists with third-party support vendor. Shared administrative accounts are in use.

3. RISK ANALYSIS

Using a 5x5 risk matrix, 8 risks were identified and assessed.

R-01 Access Control Failure: Shared emergency-admin account without MFA. Score 20 - Critical. Likelihood High due to lack of PAM. Impact Severe as it allows full system compromise.

R-02 Delayed Offboarding: Ex-contractor account t.okoro.vendor active 37 days post-exit. Score 20 - Critical. Violates least privilege principle.

R-03 Third-Party Compliance: No DPA with support vendor processing learner PII. Score 15 - High. Direct violation of GDPR Art 28 and NDPA Sec 39.

R-04 Third-Party Access: Vendor has excessive permissions without monitoring. Score 12 - High. Risk of data exfiltration.

R-05 AI Governance: AI admissions tool deployed without Data Protection Impact Assessment. Score 12 - High. Risk of algorithmic bias and non-compliance with ISO 42001.

R-06 Data Breach: Public storage container misconfiguration caused disclosure of 1240 records. Score 20 - Critical. This is the realized risk.

R-07 Segregation of Duties: Finance officer performs both payment approval and reconciliation. Score 12 - High. Fraud risk.

R-08 Incident Response: Escalation to management took 3.5 hours, risking breach of 72-hour NDPA notification window. Score 15 - High.

Top 3 risks by score are R-01, R-02, and R-06.

4. CONTROL FRAMEWORK GAPS

A Common Control Framework of 10 controls was mapped to ISO/IEC 27001:2022, NIST CSF 2.0, and NDPA 2023.

Key Gaps Identified:

1. C-01 IAM: Preventive control failed. Shared accounts exist. MFA coverage at 85% vs 100% target.
2. C-02 Vendor Risk: Detective control failed. No DPA or audit reports obtained.
3. C-04 Incident Response: Corrective control failed. No formal playbook. Escalation exceeded internal SLA.
4. C-06 AI Governance: Preventive control missing. No DPIA process for AI tools.
5. C-08 SoD: Preventive control failed in Finance function.

Control Testing confirmed 3 Failures in C-01, C-02, and C-04. See Control Tests tab and Evidence folder.

5. RISK APPETITE STATEMENT

NexaLearn has a LOW risk appetite for any risk that impacts the confidentiality, integrity, and availability of learner personal data. The organization has ZERO tolerance for regulatory non-compliance with NDPA and GDPR. The organization has a MODERATE appetite for operational risks provided they are remediated within 30 days.

6. RECOMMENDATIONS & 90-DAY ACTION PLAN

Priority 1 - Immediate 0-30 Days. Budget: \$15,000

Disable shared emergency-admin account and deploy Privileged Access Management with MFA.

Force deprovisioning of t.okoro.vendor and automate offboarding workflow.

Harden cloud storage configurations and enable Data Loss Prevention alerts.

Priority 2 - Short Term 31-60 Days. Budget: \$8,000
Execute Data Processing Agreements with all vendors processing PII.
Separate Finance duties to enforce Segregation of Duties.
Formalize Incident Response Playbook with 72-hour notification SLA.

Priority 3 - Medium Term 61-90 Days. Budget: \$10,000
Conduct Data Protection Impact Assessment for AI admissions tool.
Implement quarterly vendor risk reviews and access recertification.
Total Budget Request: \$33,000

7. CONCLUSION

The data breach was preventable and highlights fundamental gaps in access control and third-party management. The Board must approve the proposed \$33,000 remediation budget immediately to reduce regulatory exposure and restore stakeholder trust. Failure to act will likely result in NDPA fines of up to 2% of annual revenue and GDPR fines of up to 4% of global revenue.

NexaLearn Digital Services Limited experienced a data breach on 12 August 2025 resulting in the disclosure of 1,240 learner records. The root causes were a misconfigured public storage container, use of shared emergency-admin credentials without MFA, and delayed offboarding of a contractor account. This GRC assessment identified 8 material risks across Access Management, Third-Party Risk, AI Governance, and Regulatory Compliance. The organization's current control maturity is rated as 'Developing'. Without immediate remediation, NexaLearn faces potential regulatory fines under NDPA 2023 and GDPR, and reputational damage. This report recommends a 90-day remediation plan requiring Board approval of \$33,000.

2. ORGANIZATIONAL CONTEXT

NexaLearn is a Nigerian EdTech company providing online learning to 18,000 learners, including EU residents. The organization employs 60 full-time staff and 25 contractors.

Critical Assets: Learner Personally Identifiable Information (PII), Payment Card Data, Learning Management System (LMS), and AI-based Admissions Tool.

Regulatory Landscape: NexaLearn is subject to Nigeria Data Protection Act 2023 due to location, and GDPR due to processing of EU learner data. Contractual obligations include PCI DSS v4.0 for payment processing.

Assumptions: Breach has occurred. No Data Processing Agreement exists with third-party support vendor. Shared administrative accounts are in use.

3. RISK ANALYSIS

Using a 5x5 risk matrix, 8 risks were identified and assessed.

R-01 Access Control Failure: Shared emergency-admin account without MFA. Score 20 - Critical. Likelihood High due to lack of PAM. Impact Severe as it allows full system compromise.

R-02 Delayed Offboarding: Ex-contractor account t.okoro.vendor active 37 days post-exit.

Score 20 - Critical. Violates least privilege principle.

R-03 Third-Party Compliance: No DPA with support vendor processing learner PII. Score 15 - High. Direct violation of GDPR Art 28 and NDPA Sec 39.

R-04 Third-Party Access: Vendor has excessive permissions without monitoring. Score 12 - High. Risk of data exfiltration.

R-05 AI Governance: AI admissions tool deployed without Data Protection Impact Assessment. Score 12 - High. Risk of algorithmic bias and non-compliance with ISO 42001.

R-06 Data Breach: Public storage container misconfiguration caused disclosure of 1240 records. Score 20 - Critical. This is the realized risk.

R-07 Segregation of Duties: Finance officer performs both payment approval and reconciliation. Score 12 - High. Fraud risk.

R-08 Incident Response: Escalation to management took 3.5 hours, risking breach of 72-hour NDPA notification window. Score 15 - High.

Top 3 risks by score are R-01, R-02, and R-06.

4. CONTROL FRAMEWORK GAPS

A Common Control Framework of 10 controls was mapped to ISO/IEC 27001:2022, NIST CSF 2.0, and NDPA 2023.

Key Gaps Identified:

1. C-01 IAM: Preventive control failed. Shared accounts exist. MFA coverage at 85% vs 100% target.
2. C-02 Vendor Risk: Detective control failed. No DPA or audit reports obtained.
3. C-04 Incident Response: Corrective control failed. No formal playbook. Escalation exceeded internal SLA.
4. C-06 AI Governance: Preventive control missing. No DPIA process for AI tools.
5. C-08 SoD: Preventive control failed in Finance function.

Control Testing confirmed 3 Failures in C-01, C-02, and C-04. See Control Tests tab and Evidence folder.

5. RISK APPETITE STATEMENT

NexaLearn has a LOW risk appetite for any risk that impacts the confidentiality, integrity, and availability of learner personal data. The organization has ZERO tolerance for regulatory non-compliance with NDPA and GDPR. The organization has a MODERATE appetite for operational risks provided they are remediated within 30 days.

6. RECOMMENDATIONS & 90-DAY ACTION PLAN

Priority 1 - Immediate 0-30 Days. Budget: \$15,000

Disable shared emergency-admin account and deploy Privileged Access Management with MFA.

Force deprovisioning of t.okoro.vendor and automate offboarding workflow.

Harden cloud storage configurations and enable Data Loss Prevention alerts.

Priority 2 - Short Term 31-60 Days. Budget: \$8,000

Execute Data Processing Agreements with all vendors processing PII.

Separate Finance duties to enforce Segregation of Duties.

Formalize Incident Response Playbook with 72-hour notification SLA.

Priority 3 - Medium Term 61-90 Days. Budget: \$10,000

Conduct Data Protection Impact Assessment for AI admissions tool.

Implement quarterly vendor risk reviews and access recertification.

Total Budget Request: \$33,000

7. CONCLUSION

The data breach was preventable and highlights fundamental gaps in access control and third-party management. The Board must approve the proposed \$33,000 remediation budget immediately to reduce regulatory exposure and restore stakeholder trust. Failure to act will likely result in NDPA fines of up to 2% of annual revenue and GDPR fines of up to 4% of global revenue.